

Manual 54 — Gestión de Riesgo de Modelos de IA y Validación Independiente

Fuente controlada de publicación — español latinoamericano (es-419)

Fecha de verificación: 1 de septiembre de 2026

Estado de liberación: fuente candidata

Propósito

Este manual establece un programa práctico de gestión de riesgo de modelos y validación independiente para IA predictiva, IA generativa, sistemas RAG e IA agéntica. Integra principios de riesgo empresarial con métodos de prueba, evaluación, verificación y validación (TEVV), preservando el alcance real y el estado normativo de cada fuente.

Disciplina sobre el estado de las fuentes

NIST AI RMF 1.0 es orientación voluntaria y se encuentra en revisión. NIST AI 200-2 TEVV-Athlon es un borrador público inicial en 2026 y se trata como guía emergente de evaluación, no como estándar obligatorio final. NIST AITE es un programa voluntario de evaluación. Para organizaciones bancarias de EE. UU., la guía supervisora de riesgo de modelos aplica dentro de su ámbito sectorial y no debe presentarse como obligación universal para organizaciones no bancarias. El principio central es un enfoque proporcional al perfil de riesgo, tamaño, complejidad y materialidad.

Modelo operativo de validación

Caso de uso/materialidad → inventario → supuestos/limitaciones → datos → metodología/implementación → desempeño/robustez → seguridad/equidad/explicabilidad → pruebas GenAI/RAG/agénticas → supervisión humana → desafío a terceros → hallazgos/disposición → monitoreo/revalidación.

MRM-01 — Clasificación del caso de uso y materialidad

Validar propósito de negocio, partes afectadas, consecuencia de decisiones, autonomía, sensibilidad de datos, impacto financiero u operativo, exposición regulatoria y reversibilidad. Registrar materialidad, propietario responsable, nivel de aprobación y ruta de escalamiento.

MRM-02 — Inventario del modelo y del sistema

Validar modelo, proveedor, versión, orquestación, prompts del sistema, almacenes de recuperación, herramientas, agentes, flujos de datos, hosting y dependencias. El inventario debe cubrir el sistema de IA completo y no únicamente el modelo matemático o fundacional.

MRM-03 — Supuestos y limitaciones

Identificar supuestos explícitos e implícitos, rangos operativos soportados, incertidumbre, modos de falla conocidos, usos prohibidos, condiciones límite y dependencia de afirmaciones de terceros. El validador independiente debe cuestionar supuestos materiales y no limitarse a repetir la documentación del equipo de desarrollo.

MRM-04 — Validación de datos

Evaluar procedencia, linaje, representatividad, calidad, fuga de datos, duplicación, contaminación, integridad de etiquetas, vigencia temporal, manejo de datos sensibles y separación entrenamiento/prueba cuando corresponda. Documentar condiciones que invaliden conclusiones de desempeño.

MRM-05 — Metodología e implementación

Evaluar si la metodología seleccionada es apropiada para el uso previsto y si la implementación productiva corresponde al diseño aprobado. Utilizar reproducibilidad, revisión de código/configuración, cálculos independientes o métodos alternativos según la materialidad.

MRM-06 — Desempeño y robustez

Probar desempeño con métricas adecuadas al objetivo, incertidumbre, escenarios de estrés, cambios de distribución, casos extremos, estabilidad, calibración cuando aplique y umbrales explícitos de falla. Evitar depender de una única métrica agregada si puede ocultar fallas relevantes por subgrupo o escenario.

MRM-07 — Seguridad y resiliencia adversarial

Desafiar inyección de prompts, envenenamiento, exfiltración, ejecución insegura de salidas, abuso de herramientas, escalamiento de privilegios, integridad de la cadena de suministro, cambios de proveedor, agotamiento de recursos y capacidad de contención. Vincular hallazgos con la evidencia de seguridad del Manual 52.

MRM-08 — Equidad y sesgo dañino

Cuando sea pertinente al caso de uso y a los requisitos aplicables, evaluar desempeño por subgrupos, indicadores de impacto dispar, variables proxy, desbalance de datos y efectividad de mitigaciones. Documentar por qué una métrica de equidad puede no ser aplicable y no afirmar que una sola métrica demuestra ausencia de sesgo dañino.

MRM-09 — Explicabilidad y trazabilidad de decisiones

Validar si explicaciones, atribución de evidencia, procedencia, registros de decisiones y justificaciones orientadas a personas son adecuadas para el caso de uso. No presentar técnicas de explicación como si revelaran una verdad interna más allá de su capacidad real.

MRM-10 — Factualidad, fundamentación y riesgo de alucinación en GenAI

Definir pruebas específicas de factualidad y fundamentación, expectativas sobre fuentes de referencia, comprobaciones de citas/procedencia, umbrales de afirmaciones no sustentadas, comportamiento de abstención, manejo de incertidumbre y reglas de escalamiento.

MRM-11 — Calidad y autorización de recuperación RAG

Validar elegibilidad de fuentes, relevancia, vigencia, autorización, aislamiento de inquilinos, fragmentación e indexación, resistencia a envenenamiento, fidelidad de citas y prevención de recuperación no autorizada. Medir tanto calidad de respuesta como integridad de la evidencia recuperada.

MRM-12 — Riesgo de acciones agénticas

Validar identidad del agente, autoridad delegada, permisos de herramientas, límites de acción, umbrales de aprobación humana, delegación entre agentes, límites de transacción/recursos, reversión, contención y registros atribuibles. Probar salvaguardas bajo instrucciones ambiguas o adversariales.

MRM-13 — Efectividad de la supervisión humana

Probar si los revisores asignados pueden comprender, intervenir, rechazar, anular, detener, escalar y documentar decisiones antes de una consecuencia material. La mera presencia nominal de una persona no constituye supervisión efectiva si el diseño impide una intervención significativa.

MRM-14 — Validación de dependencias de terceros

Cuestionar afirmaciones de proveedores, tarjetas de modelo, declaraciones de seguridad, avisos de cambio, compromisos contractuales, continuidad, controles de versión, opciones de salida y disponibilidad de evidencia. Registrar qué afirmaciones fueron reproducidas de manera independiente y cuáles siguen dependiendo de declaraciones del proveedor.

MRM-15 — Monitoreo y revalidación

Definir métricas, umbrales de deriva, incidentes, cambios de proveedor/modelo/datos/herramientas, fallas de control, deterioro de desempeño y disparadores temporales de revalidación. El alcance de la revalidación debe corresponder a la materialidad del cambio.

MRM-16 — Hallazgos, aprobación condicional y disposición

Clasificar hallazgos por severidad y materialidad. Registrar remediación, controles compensatorios, riesgo residual aceptado, aprobación condicional, restricciones de uso, fechas de expiración y evidencia de cierre. Los hallazgos graves no resueltos requieren una disposición explícita de un responsable con autoridad; el equipo de validación debe poder documentar desacuerdo.

Criterios de independencia

La validación independiente debe estar separada organizacional e intelectualmente del desarrollo primario en proporción a la materialidad. Los validadores deben poder desafiar supuestos, reproducir o probar afirmaciones de forma independiente, documentar desacuerdos, escalar hallazgos no resueltos y evitar validar sus propias decisiones de diseño sin controles compensatorios.

Paquete de escenarios requerido

1. Cambio de distribución que deteriora el desempeño.
2. Cambio silencioso de versión de un proveedor alojado.
3. Alucinación de GenAI en un flujo de trabajo de consecuencia material.
4. RAG recupera evidencia obsoleta o no autorizada.
5. Un agente intenta actuar fuera de su límite aprobado.
6. Supervisión humana inefectiva en la práctica.
7. Contaminación del conjunto de evaluación con datos usados en entrenamiento o ajuste.

8. Una afirmación de un tercero no puede reproducirse independientemente.
9. Solicitud de aprobación condicional con un hallazgo de seguridad abierto.
10. Deriva material que todavía no supera un umbral numérico rígido.

Catálogo de evidencia

- EV-01 Carta y alcance de validación.
- EV-02 Evaluación de caso de uso/materialidad.
- EV-03 Inventario de modelo/sistema.
- EV-04 Diagramas de arquitectura y flujo de datos.
- EV-05 Registro de supuestos/limitaciones.
- EV-06 Pruebas de calidad y procedencia de datos.
- EV-07 Resultados reproducibles de desempeño.
- EV-08 Pruebas de robustez/estrés.
- EV-09 Resultados de pruebas adversariales y de seguridad.
- EV-10 Evaluación de equidad cuando aplique.
- EV-11 Evaluación de facticidad/fundamentación GenAI.
- EV-12 Evaluación de recuperación/autorización RAG.
- EV-13 Pruebas de límites de acción agéntica.
- EV-14 Prueba de efectividad de supervisión humana.
- EV-15 Desafío de evidencia de terceros.
- EV-16 Registro de hallazgos y remediación.
- EV-17 Registro de aprobación condicional o riesgo residual.
- EV-18 Plan de monitoreo y revalidación.

Regla de liberación

La validación no es un sello único de aprobación. La evidencia debe demostrar desafío independiente, pruebas reproducibles o de otro modo sustentables, hallazgos claros, disposición responsable y disparadores definidos de revalidación. La guía emergente debe seguir identificándose como borrador y la guía supervisora sectorial debe conservar su alcance real.